

Cryptographic Scope for KU Leuven ESAT/COSIC

Advisory and Audit Role — CommonHealth EIC Pathfinder Open 2026

WP1 (FCLC) + WP3 (CDATA data integration) · €3M total project, €0.6M WP1 · 36 months

Why COSIC

World-leading cryptography group (Preneel, Vercauteren, Rijmen, Verbauwhede, Smart) with:

- AES standardization track record (Rijmen)
- Secure aggregation / threshold cryptography (Preneel)
- Post-quantum + homomorphic encryption (Vercauteren)
- Hardware security + side-channel (Verbauwhede)

CommonHealth cryptographic core must survive EU AI Act Art. 22 scrutiny and independent academic audit. **Only a COSIC-grade advisory ensures this.**

Current cryptographic stack (to be audited)

Component	Current implementation	Audit focus
Secure aggregation	SecAgg+ with ChaCha20-Poly1305 authenticated encryption	Verify protocol correctness, threat model soundness
Seed derivation	SHA-256 based PRG for Shamir secret sharing	Assess collision resistance, key management
Dropout recovery	Shamir GF(257) t-out-of-n threshold	Verify threshold parameters, resilience to collusion
Differential privacy	Laplace mechanism, Rényi DP accounting, $\epsilon = 2.0$ currently	Advise on $\epsilon \leq 1.0$ via PATE/DP-SGD redesign
End-to-end encryption	Client↔coordinator TLS 1.3	Standard audit
Backward compatibility	None — new protocol	Greenfield formal analysis

Requested COSIC role

1. Design advisory (WP1, Months 3-12)

- Review architecture T1.1 (threat model)
- Recommend DP mechanism refinement for $\epsilon \leq 1.0$ target
- Advise on post-quantum readiness of chosen primitives
- Propose formal verification targets (e.g., ProVerif, Tamarin model)

2. Independent audit (WP1, Months 15-18)

- Code-level security audit of SecAgg+ implementation
- Formal protocol analysis
- Side-channel analysis if hardware BioSense (WP4) handles keys
- Audit report → Deliverable D1.3

3. WP3 integration (Months 18-30)

- Extend SecAgg+ to CData biological data aggregation
- Advise on multi-institutional genomics data privacy (if applicable to Phase 0)
- Homomorphic encryption feasibility for specific queries (optional, if Vercauteren's group interested)

Budget allocation within WP1

~€60-80K of WP1 €0.6M allocated to COSIC (exact figure depends on COSIC preference):

- 10-15% advisory (Months 3-12)
- Code audit (Months 15-18) — can be subcontracted or fixed-price
- Optional: student/postdoc rotation to COSIC for knowledge transfer

Deliverables COSIC would co-author

- **D1.1** (M6): Threat model document
- **D1.3** (M18): Cryptographic audit report (public, open-source)
- Joint publication: one security/privacy conference paper (e.g., CCS, USENIX, PETS)

Why this is low-risk, high-reward for COSIC

1. **Non-binding at LoI stage** — decision to formally join delayed to Grant Agreement
2. **Aligned with EU public research mission** — medical AI for longevity, Associated Country coordinator
3. **Low PM commitment** — advisory + audit, ~15-25 PMs over 36 months
4. **Publication opportunity** — production deployment of modern secure aggregation in clinical FL context
5. **Independence preserved** — COSIC audits, doesn't implement (removes COI concerns)

Alternative roles (if advisory role too committed)

- **Letter of Endorsement** (non-contractual) — supports credibility without formal consortium role
 - **External audit contract** (post-award) — single paid engagement for D1.3
 - **Student thesis topic co-supervision** — lighter touch
-

We are flexible. Primary request: one-page Letter of Support for 25 April 2026 LoI deadline. Formal scope refinement follows.